

Message Authentication Codes

Message Authentication Requirements

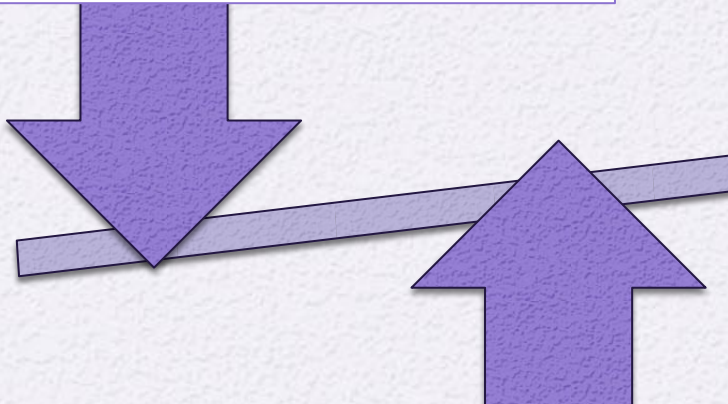
- Disclosure
 - Release of message contents to any person or process not possessing the appropriate cryptographic key
- Traffic analysis
 - Discovery of the pattern of traffic between parties
- Masquerade
 - Insertion of messages into the network from a fraudulent source
- Content modification
 - Changes to the contents of a message, including insertion, deletion, transposition, and modification
- Sequence modification
 - Any modification to a sequence of messages between parties, including insertion, deletion, and reordering
- Timing modification
 - Delay or replay of messages
- Source repudiation
 - Denial of transmission of message by source
- Destination repudiation
 - Denial of receipt of message by destination

Message Authentication Functions

- Two levels of functionality:

Lower level

- There must be some sort of function that produces an authenticator



Higher-level

- Uses the lower-level function as a primitive in an authentication protocol that enables a receiver to verify the authenticity of a message

- Hash function
 - A function that maps a message of any length into a fixed-length hash value which serves as the authenticator
- Message encryption
 - The ciphertext of the entire message serves as its authenticator
- Message authentication code (MAC)
 - A function of the message and a secret key that produces a fixed-length value that serves as the authenticator

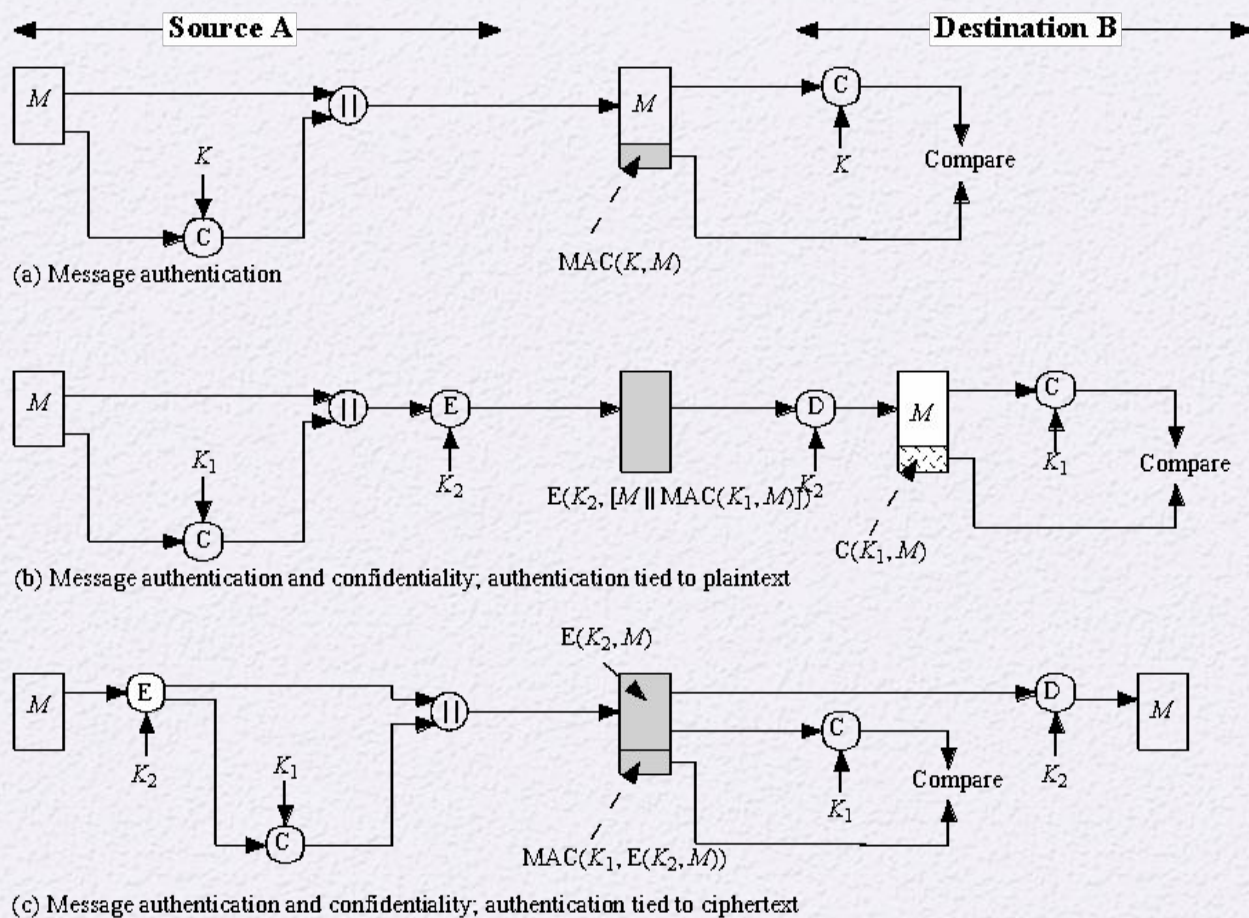
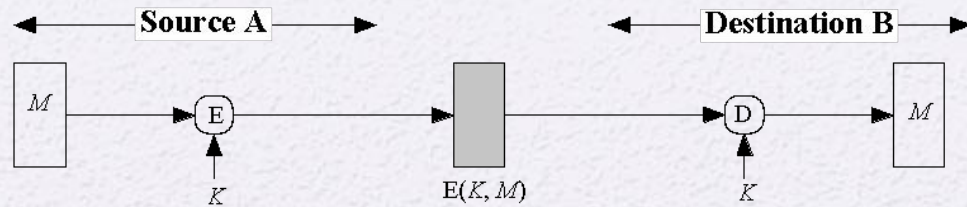
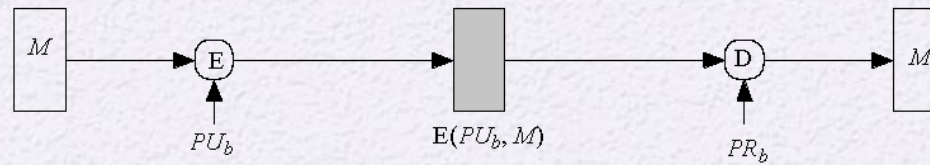


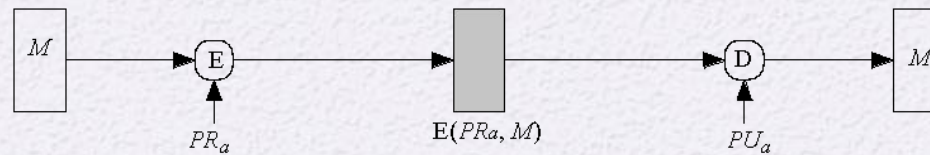
Figure 12.4 Basic Uses of Message Authentication Code (MAC)



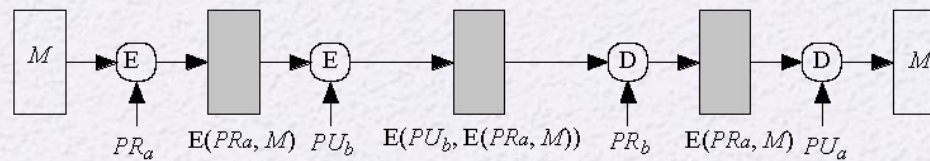
(a) Symmetric encryption: confidentiality and authentication



(b) Public-key encryption: confidentiality



(c) Public-key encryption: authentication and signature



(d) Public-key encryption: confidentiality, authentication, and signature

Figure 12.1 Basic Uses of Message Encryption

Public-Key Encryption

- The straightforward use of public-key encryption provides confidentiality but not authentication
- To provide both confidentiality and authentication, A can encrypt M first using its private key which provides the digital signature, and then using B's public key, which provides confidentiality
- Disadvantage is that the public-key algorithm must be exercised four times rather than two in each communication

Requirements for MACs

Taking into account the types of attacks, the MAC needs to satisfy the following:

The first requirement deals with message replacement attacks, in which an opponent is able to construct a new message to match a given MAC, even though the opponent does not know and does not learn the key

The second requirement deals with the need to thwart a brute-force attack based on chosen plaintext

The final requirement dictates that the authentication algorithm should not be weaker with respect to certain parts or bits of the message than others

Brute-Force Attack

- Requires known message-tag pairs
 - A brute-force method of finding a collision is to pick a random bit string y and check if $H(y) = H(x)$

Two lines of attack:

- Attack the key space
 - If an attacker can determine the MAC key then it is possible to generate a valid MAC value for any input x
- Attack the MAC value
 - Objective is to generate a valid tag for a given message or to find a message that matches a given tag

Cryptanalysis

- Cryptanalytic attacks seek to exploit some property of the algorithm to perform some attack other than an exhaustive search
- An ideal MAC algorithm will require a cryptanalytic effort greater than or equal to the brute-force effort
- There is much more variety in the structure of MACs than in hash functions, so it is difficult to generalize about the cryptanalysis of MACs

Designing MAC

HMAC (Hash-based Message Authentication Code):

- Uses a cryptographic hash function (like SHA-256) combined with a secret key to generate the MAC.
- Example: HMAC-SHA256, HMAC-SHA1.

CMAC (Cipher-based Message Authentication Code):

- Based on block cipher encryption, such as AES or DES.
- Uses the underlying block cipher in a specific mode (usually CBC) to produce a fixed-length MAC.
- Example: AES-CMAC, which is often used in network protocols and wireless communication standards.

CBC-MAC (Cipher Block Chaining Message Authentication Code):

- A simple method using the last block of ciphertext from a block cipher in CBC mode as the MAC.
- Works well only for fixed-length messages and is vulnerable for variable-length messages if not adapted properly.

GMAC (Galois Message Authentication Code):

- A MAC based on the Galois field and typically used with the Galois/Counter Mode (GCM) for encryption.
- Designed for high performance and used in secure communication protocols like TLS.

MACs Based on Hash Functions: HMAC

- There has been increased interest in developing a MAC derived from a cryptographic hash function
- Motivations:
 - Cryptographic hash functions such as MD5 and SHA generally execute faster in software than symmetric block ciphers such as DES
 - Library code for cryptographic hash functions is widely available
- HMAC has been chosen as the mandatory-to-implement MAC for IP security
- Has also been issued as a NIST standard (FIPS 198)

HMAC Design Objectives

RFC 2104 lists the following objectives for HMAC:

To use, without modifications, available hash functions

To allow for easy replaceability of the embedded hash function in case faster or more secure hash functions are found or required

To preserve the original performance of the hash function without incurring a significant degradation

To use and handle keys in a simple way

To have a well understood cryptographic analysis of the strength of the authentication mechanism based on reasonable assumptions about the embedded hash function

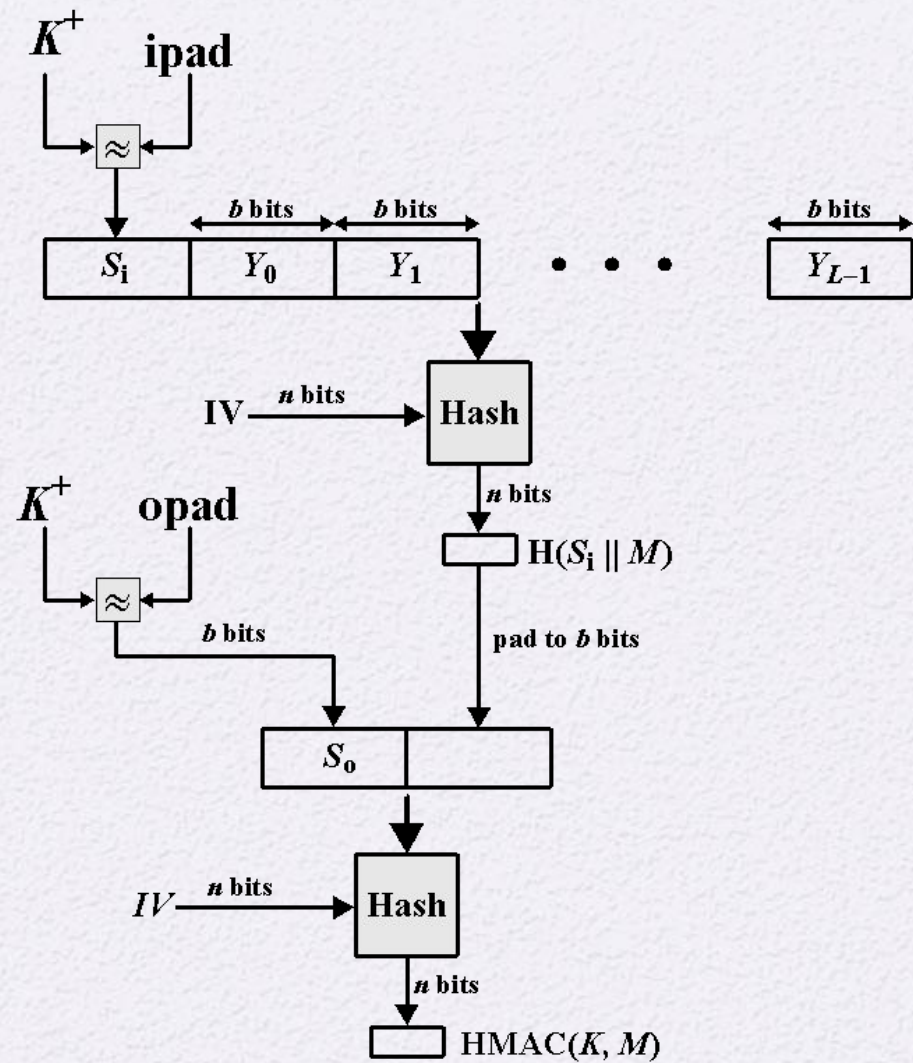


Figure 12.5 HMAC Structure

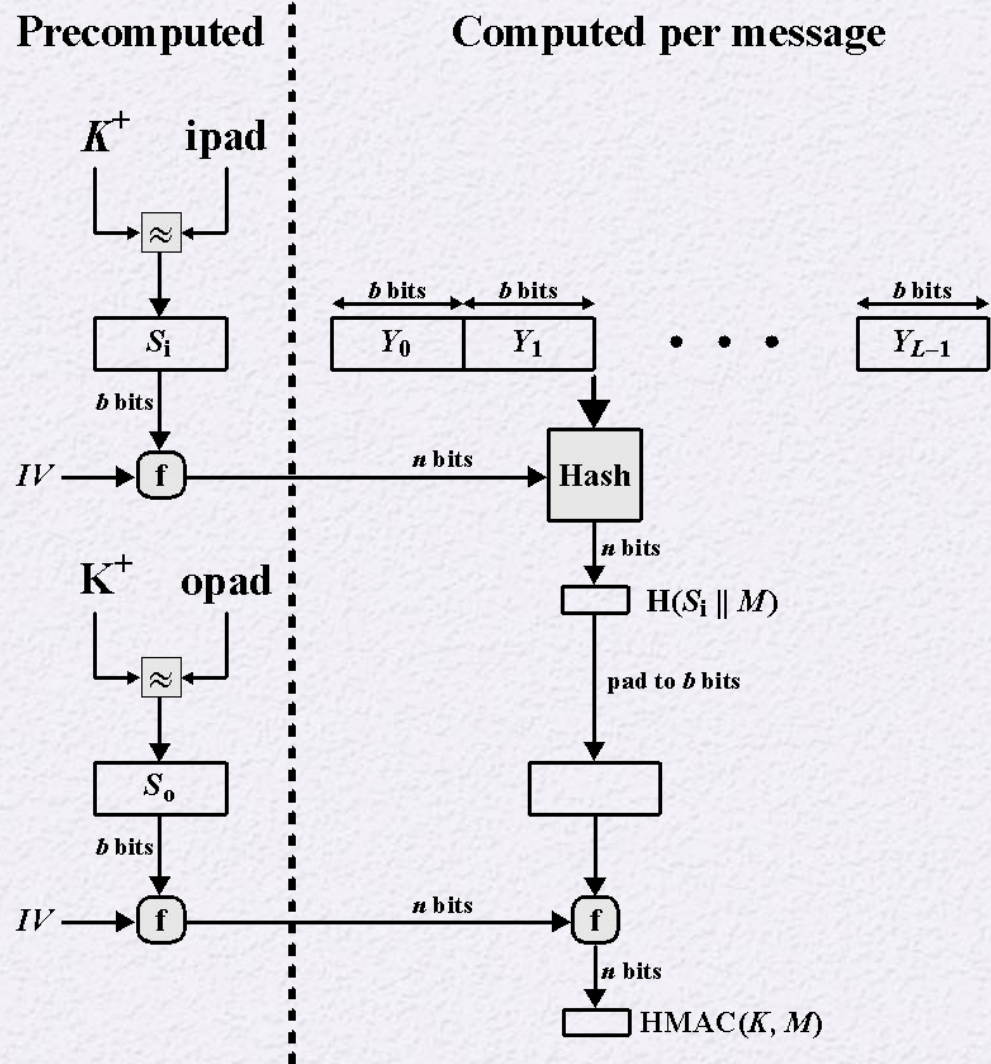
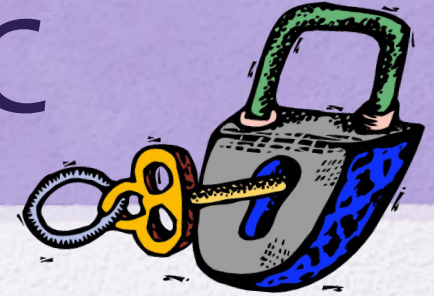


Figure 12.6 Efficient Implementation of HMAC

Security of HMAC



- Depends in some way on the cryptographic strength of the underlying hash function
- Appeal of HMAC is that its designers have been able to prove an exact relationship between the strength of the embedded hash function and the strength of HMAC
- Generally expressed in terms of the probability of successful forgery with a given amount of time spent by the forger and a given number of message-tag pairs created with the same key

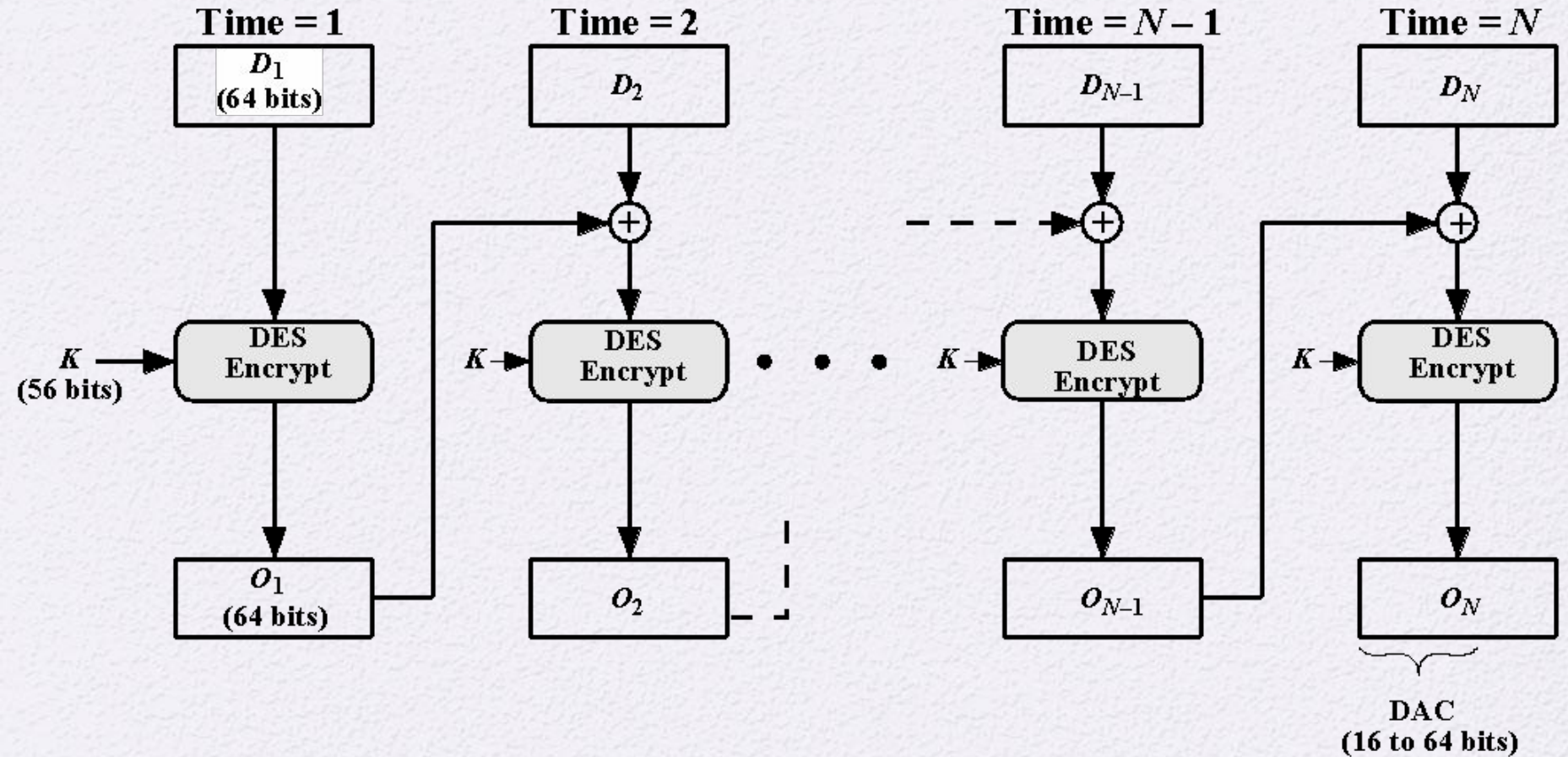
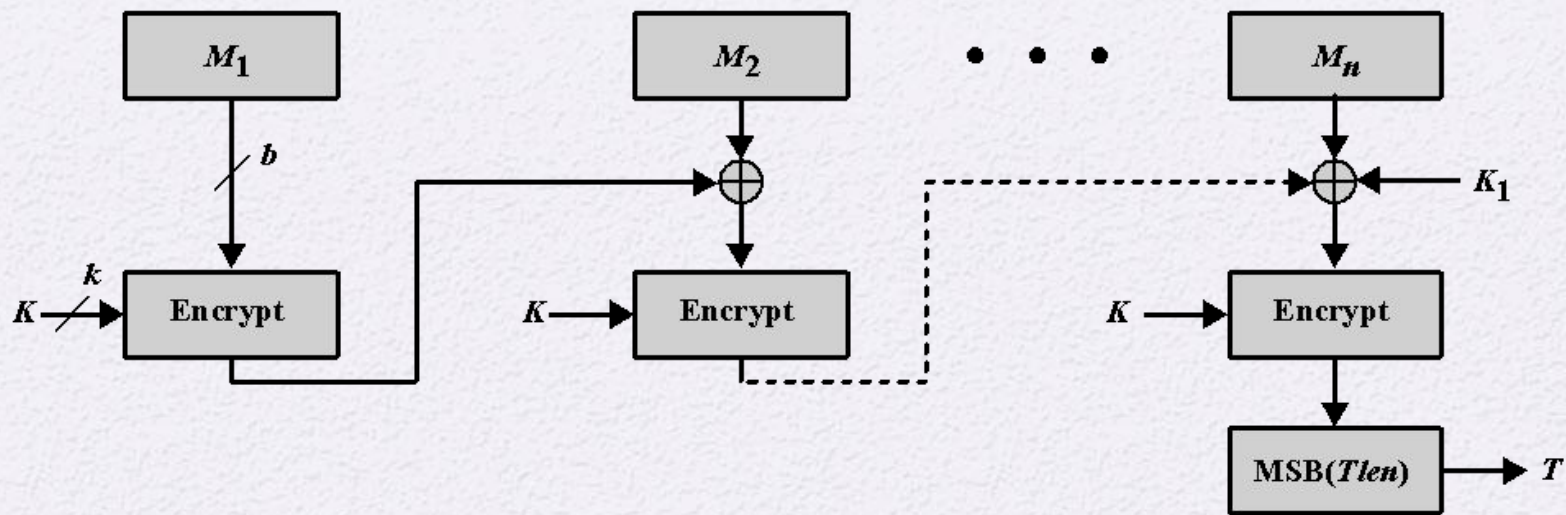
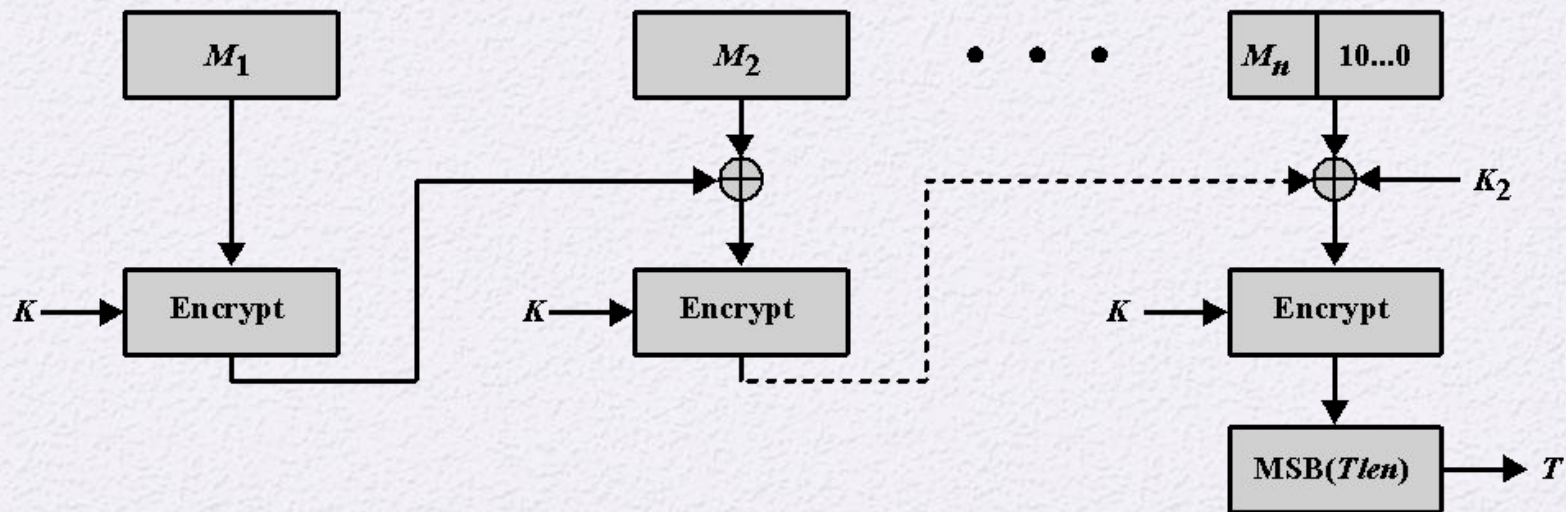


Figure 12.7 Data Authentication Algorithm (FIPS PUB 113)



(a) Message length is integer multiple of block size



(b) Message length is not integer multiple of block size

Figure 12.8 Cipher-Based Message Authentication Code (CMAC)

Authenticated Encryption (AE)

- A term used to describe encryption systems that simultaneously protect confidentiality and authenticity of communications
- Approaches:
 - Hashing followed by encryption
 - Authentication followed by encryption
 - Encryption followed by authentication
 - Independently encrypt and authenticate
- Both decryption and verification are straightforward for each approach
- There are security vulnerabilities with all of these approaches

Approaches to Authenticated Encryption

Hashing followed by Encryption:

- **Process:** First, a hash of the message is created to serve as an authenticator. Then, both the original message and the hash are encrypted together.
- **Advantage:** Ensures that any modification of the message during transmission can be detected when decrypted.
- **Vulnerability:** This approach can be vulnerable if the hashing or encryption algorithms are weak, or if an attacker can manipulate the encrypted data.

Authentication followed by Encryption:

- **Process:** A message authentication code (MAC) or digital signature is applied to the message for authenticity. Then, the entire authenticated message is encrypted.
- **Advantage:** The message is both encrypted and authenticated, protecting against tampering and unauthorized access.
- **Vulnerability:** Potential issues may arise if encryption does not fully conceal authentication information, leading to possible attacks.

Encryption followed by Authentication:

- **Process:** The message is encrypted first, and then a MAC or hash is generated based on the encrypted message to authenticate it.
- **Advantage:** Protects both the encrypted message's integrity and the confidentiality of the original data.
- **Vulnerability:** If the MAC is not securely linked to the encrypted data, attackers might be able to manipulate the message without detection.

Independently Encrypt and Authenticate:

- **Process:** The message is both encrypted and authenticated separately. The encryption provides confidentiality, while the MAC or digital signature ensures integrity.
- **Advantage:** Redundancy of security mechanisms, as each part (encryption and authentication) can independently protect the data.
- **Vulnerability:** This approach can be less efficient, and separate processing might increase complexity, leading to potential security implementation errors

Counter with Cipher Block Chaining-Message Authentication Code (CCM)

- Was standardized by NIST specifically to support the security requirements of IEEE 802.11 WiFi wireless local area networks
- Variation of the encrypt-and-MAC approach to authenticated encryption
 - Defined in NIST SP 800-38C
- Key algorithmic ingredients:
 - AES encryption algorithm
 - CTR mode of operation
 - CMAC authentication algorithm
- Single key K is used for both encryption and MAC algorithms

The input to the CCM encryption process consists of three elements:

Data that will be both authenticated and encrypted

This is the plaintext message P of the data block

Associated data A that will be authenticated but not encrypted

An example is a protocol header that must be transmitted in the clear for proper protocol operation but which needs to be authenticated

A nonce N that is assigned to the payload and the associated data

This is a unique value that is different for every instance during the lifetime of a protocol association and is intended to prevent replay attacks and certain other types of attacks

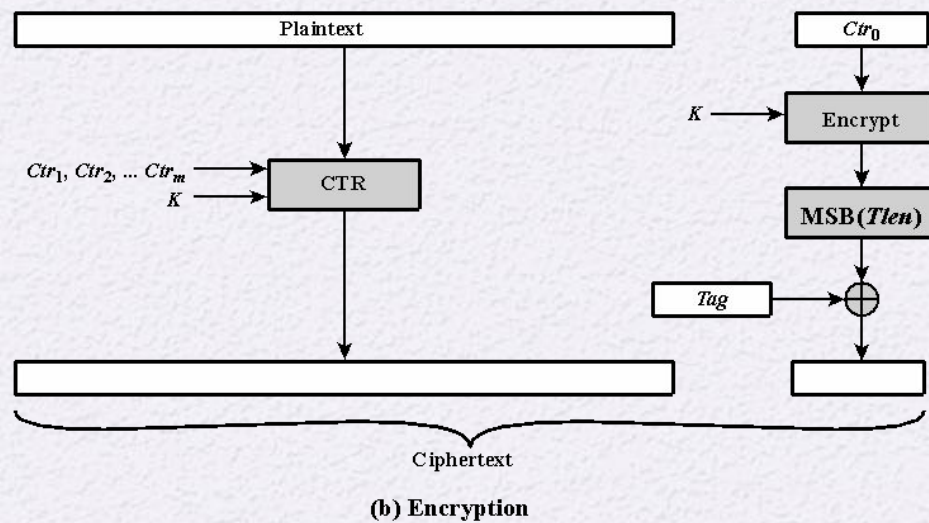
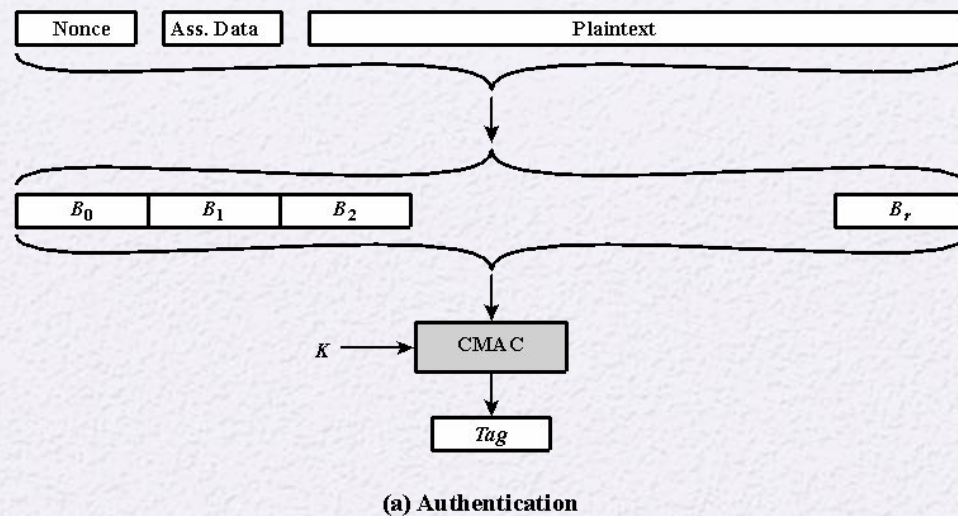
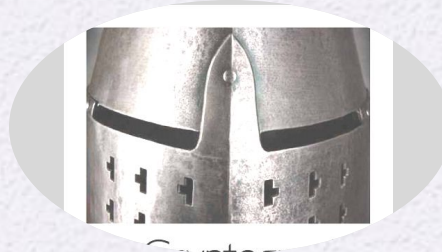


Figure 12.9 Counter with Cipher Block Chaining-Message Authentication Code (CCM)

Summary

- List and explain the possible attacks that are relevant to message authentication
- Define the term *message authentication code*
- List and explain the requirements for a message authentication code
- Present an overview of HMAC
- Present an overview of CMAC



- Explain the concept of authenticated encryption
- Present an overview of CCM
- Present an overview of GCM
- Discuss the concept of key wrapping and explain its use
- Understand how a hash function or a message authentication code can be used for pseudorandom number generation